

MemLeak: Cross-User Semantic Leakage in Multi-Tenant AI Agent Memory

Priyanka Mudgal, Kai Zhao, Guilin Zhang, Andy Olsen,
Ezekiel Miller, Xu Chu, Aletta Johanna Blanken

Workday AI Research

{priyanka.mudgal, kai.zhao, guilin.zhang, andrew.olsen,
zeke.miller, xu.chu, alet.blanken}@workday.com

Abstract

Personal AI agents in enterprise multi-tenant deployments share a common vector store for long-term memory. Shared embedding spaces create a surface for cross-user memory leakage: a user’s query can retrieve semantically adjacent memories belonging to another user through ordinary cosine-similarity retrieval, without any exploit. We formalize this as *cross-user admissibility failure* and evaluate it across six experiments, plus follow-up ablations, under both sparse (TF-IDF) and production-faithful (MiniLM-L6-v2) retrieval. Non-adversarial, incidental leakage reaches 70–100% under pooled same-team retrieval; adversarially crafted memories achieve 90–100% top- k placement, exceeding weaker keyword-based attacker baselines, with score lifts of +0.416 to +0.511 under production-faithful dense retrieval (Config B); and end-to-end response contamination reaches 5.00/5 under a production retrieval path and 4.67/5 with Claude Sonnet 4.5, with contaminated responses often scoring as helpful or more helpful than clean ones, a gap validated against human judgment. Among three architectural mitigations, only hard post-retrieval ownership gating consistently restores the clean baseline (1.00/5) across two generation models, at a measured latency overhead of roughly 1.4 ms per query.

1 Introduction

Personal AI agents are becoming a standard component of enterprise productivity software. Enterprise systems maintain persistent long-term memory for each user, allowing agents to recall preferences, project context, and prior decisions. In enterprise deployments this memory infrastructure typically serves many users concurrently, a *multi-tenant* setting in which a single shared backend infrastructure serves multiple distinct users or organizations without physical storage isolation. This is the pattern common to general-purpose agent-memory libraries (e.g., Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], MemOS [Li et al., 2025]), which are often backed by a shared vector store with metadata-based filtering that exposes per-user ownership only as soft metadata rather than a hard-enforced boundary. This architectural design introduces a threat we term *inter-user semantic resonance*, where embedding-space proximity alone pulls one user’s memories into another user’s agent session, requiring no adversarial modification of prompts, code, or model weights (Figure 1).

Prior work on memory-enabled agent trustworthiness, including Tan et al. [2025] and Wu et al. [2025], has treated memory as a single-user trust boundary. These works address when a user’s own memories should influence their own current task, identifying failure modes such as cross-domain leakage, sycophancy, tool-call drift, and memory-induced jailbreaks within a single-user context. None examine the multi-user case, e.g., what occurs when Alice’s memories reach Bob’s session.

We introduce MemLeak, a study of how shared embedding spaces in multi-tenant agent deployments cause cross-user memory leakage without any exploit or adversarial intent. Strict user partitioning is a known, effective baseline that eliminates this leakage (we confirm this directly in our own experiments, Table 1); the setting we study is the common intermediate deployment pattern where such partitioning is absent or incomplete: pooled vector stores where ownership exists as *soft metadata* rather than a hard-enforced boundary, or where cross-user memories are pooled by design for legitimate collaboration (shared project spaces, HR/security workflows). In this regime, semantic similarity, not any explicit data transfer, prompt injection, or code change, determines whether private content crosses a user boundary, and it is a poor proxy for admissibility: leakage severity does not track intuitive risk signals such as organizational distance or global embedding-centroid proximity (Section 4). Lampson’s definition of a covert channel [Lampson, 1973] applies to the intentional-exploitation experiments (E3, E6) only. We use the framing to scope the attacker-knowledge ablation (E3) and to bound active exploitation (E6); the core leakage findings (E1, E2, E4, E5) do not depend on it. E6 is included as a negative result: we find that the shared embedding space does not support reliable sequential transmission, confirming that MemLeak describes incidental cross-user leakage, not a functioning covert channel. We refer to the organic, non-adversarial version of the same failure, which dominates our results, as *incidental cross-user leakage*. This paper makes three contributions:

- We identify *inter-user semantic resonance* as a threat distinct from prior single-user memory-trustworthiness work, and characterize its severity under a specific, common deployment pattern (pooled stores with soft ownership metadata or intentionally shared collaboration scopes), rather than under the trivial case of a fully absent access-control layer.
- We formalize *cross-user admissibility failure* and define leakage metrics, a privacy–utility frontier (XLR, an exploratory Resonance Index), and preliminary covert-channel capacity measures, reporting 95% Wilson confidence intervals throughout given our sample sizes ($n = 10$ queries per condition). We present these results as a controlled proof of concept establishing the existence and mechanism of the failure mode, not as a population-level prevalence estimate (see Limitations).
- We conduct six controlled experiments under both sparse TF-IDF and production-faithful dense MiniLM retrieval, together with follow-up ablations isolating attacker knowledge assumptions, judge–human agreement, embedding-model scale, and mitigation latency, demonstrating 70–100% incidental leakage under pooled same-team retrieval, score lifts of +0.416 to +0.511 under active exploitation that exceed weaker keyword-based attacker baselines, and downstream contamination increases of +1.67 to +4.00 points on a 5-point scale depending on generation model and memory path; and a negative covert-channel capacity result (E6), included to bound the active-exploitation claim rather than assert a functioning channel.

2 Related Work

Early agentic memory architectures such as MemGPT [Packer et al., 2023] and Generative Agents [Park et al., 2023] introduced persistent recall via hierarchical memory management. Production systems including Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], and MemOS [Li et al., 2025] have since extended this to scalable multi-session deployments backed by shared vector stores. The standard retrieval paradigm encodes queries and memories using embedding models and ranks candidates by cosine similarity [Wang et al., 2022], making shared vector memory a standard enterprise component [Wang et al., 2023]. Agentic frameworks such as ReAct [Yao et al., 2023] and Reflexion [Shinn et al., 2023] further embed retrieval-augmented memory into multi-step reasoning loops. Prior work on memory trustworthiness including Pulipaka et al. [2026], Guo et al. [2026], Tan et al. [2025], and Wu et al. [2025] addresses failure modes within a single user boundary; none examine the multi-user case. Retrieval-augmented generation [Lewis et al., 2020] has become a standard grounding mechanism for LLMs. PoisonedRAG [Zou et al., 2025], Phantom [Chaudhari et al., 2024], and Shafran et al. [2025] attack the retrieval corpus directly, while indirect prompt injection [Greshake et al., 2023, Perez and Ribeiro, 2022] embeds malicious instructions in retrieved content. Inter-user semantic resonance requires neither: retrieved memories are ordinary professional notes containing no adversarial instructions, and harm arises purely from their presence in Bob’s context rather than from any instruction they contain. Language models leak information through weights and outputs [Carlini et al., 2021, Kandpal et al., 2022], and text embeddings reveal nearly as

much as the original text [Morris et al., 2023]. Feyisetan et al. [2020] propose calibrated noise in embeddings as a privacy-preserving transformation, motivating our M2 mitigation. Covert channels were formalized by Lampson [1973] and extended by Denning [1976] and Myers and Liskov [1997]; we identify the shared embedding space as a covert channel medium in AI agent systems. We evaluate downstream contamination using LLM-as-judge following Zheng et al. [2023].

3 Threat Model and Formalization

3.1 System Model

We consider a multi-tenant personal agent deployment with N users $\{U_1, \dots, U_N\}$. Each user U_i maintains a memory store $\mathcal{M}_i = \{m_1, \dots, m_k\}$, where each memory m_j is mapped to an embedding $\mathbf{v}_m \in \mathbb{R}^d$. In a *pooled* deployment, all memories reside in a single vector index with optional `user_id` metadata filtering; in a *partitioned* deployment, each user has a separate index. A query from user U_i is embedded as $\mathbf{q} \in \mathbb{R}^d$, and the top- k memories by cosine similarity are injected into the LLM context.

3.2 Cross-User Admissibility Failure

We define the cross-user admissibility indicator $\mathcal{A}(m, x_q, U_i) \in \{0, 1\}$ such that $\mathcal{A} = 1$ if and only if memory m belongs to user U_i and is contextually appropriate for query x_q . For any memory m owned by user $U_j \neq U_i$, $\mathcal{A}(m, x_q, U_i) = 0$ by definition, regardless of semantic similarity. A cross-user leakage event occurs when:

$$\text{rank}(S(\mathbf{q}, \mathbf{v}_m)) \leq k \wedge \text{owner}(m) \neq U_i \quad (1)$$

3.3 Leakage Probability

We define the leakage probability for a user pair (U_i, U_j) as:

$$L(U_i, U_j) = \mathbb{E}[\mathbf{1}\{\text{cross-user retrieval}\} \mid \mathbf{q} \sim U_i] \quad (2)$$

We hypothesize that $L(U_i, U_j)$ increases with the cosine similarity between memory centroids $\mathbf{c}_i$ and $\mathbf{c}_j$, where $\mathbf{c}_i = \text{mean}(\{\mathbf{v}_m : m \in \mathcal{M}_i\})$.

3.4 Threat Scenarios

Passive leakage. Users interact normally. Cross-user retrieval occurs organically due to shared vocabulary, roles, or organizational context. No adversarial intent is required.

Active exploitation. An adversary (Mallory) crafts memories designed to appear highly similar to a target user’s expected queries, potentially steering recommendations, decisions, or tool calls through ordinary conversational interaction. We specify Mallory’s knowledge explicitly in Section 4.5: she knows the victim’s general domain and role (e.g., that Bob handles budget approvals) but not his exact queries or the embedding model’s internals, and does not have oracle access to his input stream.

3.5 Deployment Patterns and the ACL Baseline

We treat strict user partitioning as the access-control (ACL) baseline: our own results confirm it drives passive leakage to 0% (Table 1) and blocks even cross-user query wording aimed at a partitioned index (Section 4.10, M1). MemLeak’s threat model targets four deployment patterns in which cross-user memories remain reachable by design or common misconfiguration – pooled indices with under-scoped metadata filters, team- or role-scoped retrieval in which a compromised or malicious in-scope member becomes an attacker, shared project namespaces, and scoped enterprise workflows (HR, finance, security) where cross-user content belongs in the retrieval pool by policy but admissibility should still depend on more than raw similarity. These patterns follow those documented in general-purpose agent-memory libraries such as Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], and MemOS [Li et al., 2025] (full taxonomy in Appendix D). Our contribution is to quantify residual risk once a store is pooled or its scope is widened for these reasons, and to show that similarity ranking alone does not restore admissibility even within an authorized pool.

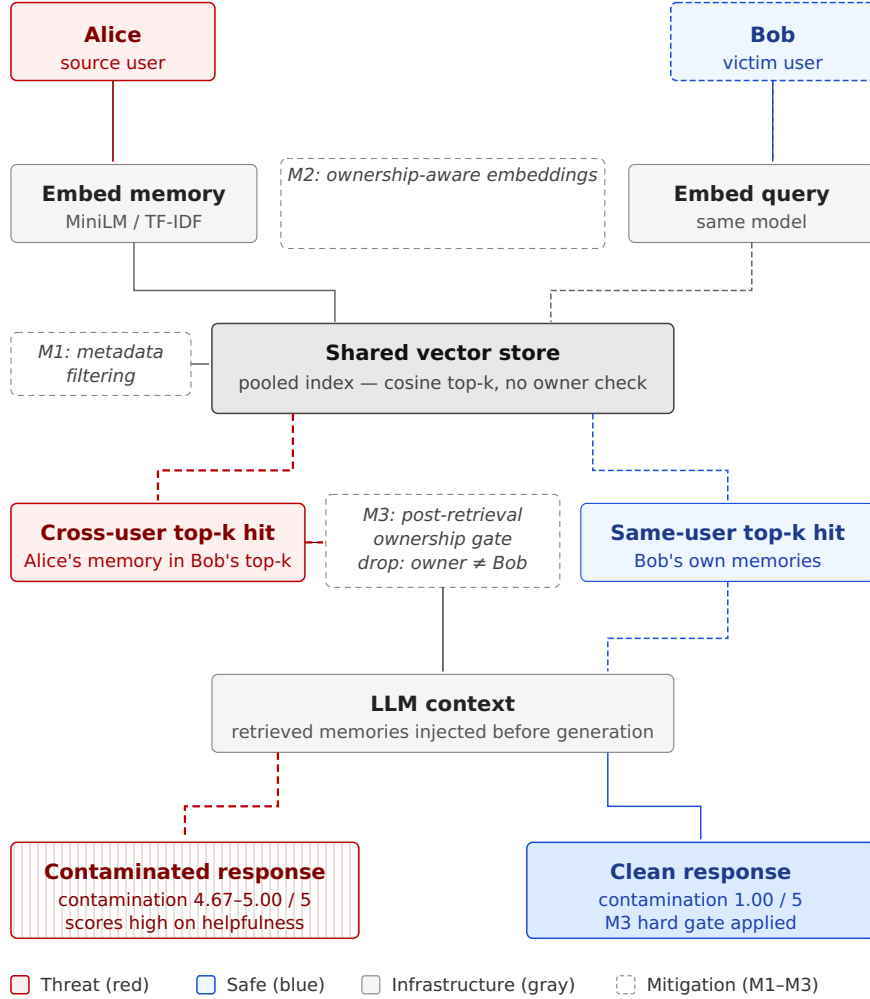


Figure 1: **MemLeak architecture.** Alice’s memories and Bob’s query co-exist in a shared vector store; cosine top- k retrieval pulls Alice’s memories into Bob’s context without an ownership check (dashed red path), constituting a cross-user admissibility failure (§3). Dashed bordered boxes mark the three mitigation intercept points: **M1** (metadata filtering at the store), **M2** (ownership-aware embeddings), and **M3** (post-retrieval ownership gating).

4 Experiments

4.1 Experimental Setup

User profiles. We construct four pairs of synthetic user profiles at varying organizational distances: same team (T0), same department (T1), cross-department (T2), and cross-company (T3, control). Each user holds 10 memories covering private professional information (salary negotiations, security vulnerabilities, HR decisions, platform details). Each target user has 10 domain-specific queries. All memories and queries are hand-authored, fixed natural-language fixtures rather than samples drawn from real user data or logs, spanning four domain categories held constant across all four organizational-distance tiers so that tier comparisons isolate organizational distance rather than content variation (full fixture text in Appendix E). We treat this as a controlled proof-of-concept design intended to establish the existence and mechanism of the failure mode, not a population-level estimate of real enterprise leakage rates (see Limitations). Because each rate in Sections 4–4.10 is computed

Config	Mode	LR	MCR	Gap
A: TF-IDF	Pooled	100% [72,100]	1.60	+0.244
A: TF-IDF	Partitioned	0% 70% [40,89]	n/a	n/a
B: MiniLM	Pooled	70% [40,89]	1.71	+0.095
B: MiniLM	Partitioned	0%	n/a	n/a

Table 1: E1 existence proof (T0, Alice/Bob). LR = leakage rate over $n = 10$ queries, with 95% Wilson-score CI stacked below; MCR = mean cross-user rank; Gap = score gap.

Scenario	Cfg. A		Cfg. B	
	Pl.%	Lift	Pl.%	Lift
Salary	100%	+0.407	90%	+0.416
Security	100%	+0.383	100%	+0.503
Budget	100%	+0.484	100%	+0.511

Table 2: E3 active exploitation (scenario abbreviated: Salary Negotiation, Security Policy, Budget Authority). Pl.% = top- k placement rate for crafted memories; Lift = mean score increase over organic baseline.

over $n = 10$ queries per condition, we report 95% Wilson-score confidence intervals alongside every proportion and explicitly flag which comparisons are and are not statistically distinguishable at this sample size.

Retrieval configurations. We evaluate two retrieval configurations. **Config A** (sparse baseline) uses TF-IDF with truncated SVD (128 dimensions) and isolated query embedding. **Config B** (production-faithful) uses all-MiniLM-L6-v2 with query-document retrieval prefixes following standard asymmetric dense retrieval practice [Wang et al., 2022]. Both configurations rank candidates by cosine similarity under pooled (no access control) and partitioned (user-scoped) modes, with top- $k = 3$.

Downstream evaluation. Downstream response contamination is evaluated under two memory paths (Section 4.6). The *static path* injects fixed clean or leaked memory lists directly into the prompt. The *retrieval path* retrieves memories via Config B before generation, testing the full retrieve-then-generate pipeline. We evaluate Gemini 2.5 Flash Comanici et al. [2025] and Claude Sonnet 4.5 Anthropic, 2025] as both generator and judge (temperature = 0), rating responses on contamination (1–5) and helpfulness (1–5). Appendix B (Table 9) summarizes all metrics used below.

4.2 E1: Existence Proof

Setup. We use the T0 same-team pair (Alice: Senior Engineer; Bob: Engineering Manager). Alice’s memories include salary negotiations, a competing offer, equity vesting, and burnout indicators. Bob issues 10 managerial queries covering performance reviews, compensation, and project restructuring. Under pooled retrieval, cross-user leakage is systematic in both configurations (Table 1). Config A exhibits 100% LR with a larger score gap (+0.244), consistent with sparse TF-IDF increasing lexical overlap. Config B reduces incidental leakage to 70% while maintaining mean cross-user rank below 2.0; its 95% Wilson interval ([40%, 89%]) is wide at this sample size, so we treat 70% as indicative rather than precise. Under partitioned retrieval, LR = 0% in both configurations with no cross-user hits observed, confirming that user-scoped indexing eliminates incidental leakage in our fixtures; this partitioned condition is the ACL baseline described in Section 3.5.

4.3 E2: Leakage Rate vs. Organizational Distance

The cross-company control (T3) drops to 10% LR under Config B (95% CI [2%, 40%]) with mean cross-user rank 3.00, a robust contrast with pooled retrieval generally (70–100% across T0–T2; Table 3). T1 and T2 show a nominally higher leakage rate (90%) than T0 (70%) despite T0 having the highest centroid similarity (0.570); at $n = 10$ the Wilson intervals for 70% and 90% overlap substantially, so this fine-grained ordering is not statistically distinguishable from chance (extended discussion in Appendix D). The claim we consider robust is coarser: *centroid similarity is not a reliable predictor of leakage risk* in either sparse or dense retrieval. T3 has the lowest centroid similarity (0.284) and, correspondingly, the lowest and most confidently distinguishable leakage rate (10%), but among T0–T2 the ranking by centroid similarity does not match the ranking by leakage rate closely enough to support a fine-grained causal story. Under Config A, centroid similarities are uniformly low (0.035–0.075) while leakage remains 50–100%, confirming that sparse retrieval

Tier	LR _B	Sim _B	LR _A	Sim _A
T0: Same Team (A/B)	70% [40,89]	0.570	100% [72,100]	0.075
T1: Same Dept (C/D)	90% [60,98]	0.379	90% [60,98]	0.044
T2: Cross Dept (E/G)	90% [60,98]	0.488	100% [72,100]	0.068
T3: Cross Co. (H/I)	10% [2,40]	0.284	50% [24,76]	0.035

Table 3: E2 leakage rate (LR, with 95% Wilson CI, $n = 10$) and centroid similarity (Sim) by tier. User initials: A=Alice, B=Bob, C=Carol, D=Dave, E=Eve, G=Grace, H=Heidi, I=Ivan. Subscripts: B=MiniLM, A=TF-IDF.

Tier	XLR	Util.	RI	Sim.	Gap
T0: Same Team	70%	0.384	0.509	0.570	+0.095
T1: Same Dept.	90%	0.325	0.511	0.379	+0.189
T2: Cross Dept.	90%	0.147	0.549	0.488	+0.302
T3: Cross Co.	10%	0.507	0.162	0.284	-0.012

Table 4: E5 privacy–utility frontier (Config B, pooled). RI = Resonance Index; Util. = same-user retrieval utility; Sim. = centroid similarity.

decouples global centroid proximity from query-level lexical overlap; org-chart distance is similarly unreliable as a fine-grained proxy (Section 4.8).

4.4 E3: Active Exploitation

Crafted memories achieve 90–100% top- k placement in both configurations, compared with organic placement as low as 10% (Salary Negotiation, Config B; Table 2), reaching 0% in some scenarios (full grid in Appendix F), and as high as 70% (Budget Authority, Config A). Config B shows lower organic placement (0–10%) but equal or higher score lifts, suggesting that dense embeddings make passive attacker presence harder to detect while crafted bridging remains effective. The Budget Authority scenario is a notable edge case: Config A organic placement already reaches 70%, because budget vocabulary (approval thresholds, procurement language) is broadly shared across roles, which compresses the marginal gain from crafting and represents an incidental leakage risk independent of adversarial intent, consistent with E1–E2 (extended discussion in Appendix D).

4.5 E3b: Attacker Knowledge and Crafting Baselines

E3’s crafted-memory results leave open how much of Mallory’s advantage comes from the specific crafting method versus simply from having any topical knowledge of the victim at all. We make Mallory’s assumed knowledge explicit and compare our crafted bridging memories against three baselines of increasing query knowledge, run on the Salary Negotiation scenario under both configurations ($k = 3$; 95% Wilson CIs): (1) *organic baseline*: Mallory’s unmodified notes, no query knowledge; (2) *domain keyword bag*: memories seeded with shared high-frequency domain vocabulary but no query-specific terms; (3) *per-query keywords*: memories seeded with terms drawn from the specific target query; (4) *crafted bridging (ours)*: memories that frame the same topic/context as the target’s queries without copying query text, representing an attacker who knows the victim’s domain and role but not their exact queries or the embedding model’s internals; and (5) *verbatim copy*, an oracle upper bound in which Mallory has direct access to the target’s query text. Under Config B, placement rises monotonically with assumed attacker knowledge: 10% (organic) $\rightarrow$ 40% (domain keyword bag) $\rightarrow$ 80% (per-query keywords) $\rightarrow$ 90% (crafted bridging, ours) $\rightarrow$ 100% (verbatim-copy oracle), with score lifts over the organic baseline of +0.182, +0.345, and +0.416 respectively (full table, including Config A and Wilson CIs, in Appendix F). Two results bound how much crafting itself contributes beyond raw vocabulary overlap. First, a bare domain keyword bag with no query-specific knowledge already reaches 40% placement, showing that some of the attacker’s advantage comes cheaply from shared domain vocabulary alone. Second, our crafted-bridging condition (90%), which assumes only domain/role knowledge and not exact query access, closes most of the remaining gap to the oracle verbatim-copy upper bound (100%), indicating that an attacker does not need query-level or model-level access to achieve most of the exploitable advantage: topical framing suffices. We report this ablation only for Salary Negotiation in the main text; the full scenario $\times$ baseline $\times$ configuration grid is in Appendix F.

Path	Model	Clean	Leaked	Help.
Static	Gemini 2.5 Flash Claude	1.00	2.67	4.80
Static	Sonnet 4.5 Gemini	1.00	4.67	4.53
Retrieval	2.5 Flash Claude	1.00	5.00	5.00
Retrieval	Sonnet 4.5	1.00	4.67	2.67

Table 5: E4 downstream contamination (mean over 3 scenarios). Clean baseline = 1.00 in all conditions. Help. = mean helpfulness of leaked responses.

Condition	Store	Queries	Sal.	Sec.	Bud.
Pooled baseline	pooled	same-user	90%	100%	100%
Passive	partitioned	same-user	0%	0%	0%
safe Cross-query	partitioned	cross-user	0%	0%	0%
blocked Active failure	scoped_cross	cross-user	100%	100%	90%

Table 6: M1: crafted-memory top- k placement rate for attacker (Mallory).

4.6 E4: Downstream Response Contamination

Leaked memories increase mean contamination from 1.00 (clean) to 2.67–5.00 depending on model and path (Table 5). The retrieval path with Gemini 2.5 Flash yields maximum contamination (5.00/5, $\Delta = +4.00$), demonstrating that end-to-end retrieval increases downstream harm relative to static injection. Claude Sonnet 4.5 achieves 4.67/5 under both static and retrieval paths, with explicit cross-user attribution observed in generated text for the salary scenario. Leaked memories provide genuinely useful context, such as salary benchmarks in compensation discussions and vulnerability specifics in security planning, making responses more actionable while violating privacy. Standard response-quality monitoring is therefore insufficient to detect this failure mode. Because E4 uses each generator as its own judge, we separately validated judge reliability against human annotation on a held-out pilot (E0, Section 4.7); agreement was strong on clean controls and on helpfulness but weaker on contamination, and where it erred the judge underestimated rather than overestimated disclosure, so we treat our contamination numbers as a conservative lower bound.

4.7 E0: LLM-Judge / Human Agreement Pilot

To assess whether our LLM-as-judge contamination and helpfulness scores (E4, M3) are trustworthy, two authors independently labeled nine synthetic E4 responses against the same rubric given to the LLM judge (full protocol and per-scenario table in Appendix G). Agreement is high on clean controls and helpfulness (mean absolute error 0.53) but weaker on contamination overall (MAE 0.79), driven almost entirely by a single miss on the Security scenario where the judge under-scored an unpatched-CVE detail as generic advice. This miss is directionally conservative (the judge under-scores rather than over-scores disclosure), so we treat our reported E4/M3 contamination numbers as a lower bound on true leakage severity rather than an inflated estimate.

4.8 E5: Cross-User Privacy–Utility Frontier

T3 achieves the lowest Resonance Index (0.162) and highest utility (0.507), occupying the favorable corner of the privacy–utility frontier; T0–T2 exhibit high XLR (70–90%) with moderate utility (0.147–0.384; Table 4). T2 (cross-department) shows the highest Resonance Index (0.549, an exploratory, uncalibrated composite; see Appendix B, Table 9) and the highest score gap (+0.302) among the four tiers – the margin by which leaked memories outscore the querying user’s own memories when leakage occurs. As with the T1/T2-vs-T0 ordering in E2, we treat this fine-grained ranking across T0–T2 as suggestive rather than statistically established at $n = 10$ per tier (extended discussion in Appendix D). The claim we consider robust is coarser: the cross-company control sits in a clearly separated, favorable region of low leakage and high utility, while any pooled in-organization retrieval (T0–T2) carries substantially higher risk regardless of its finer internal ordering – *organizational distance alone should not be relied on as a fine-grained proxy for memory isolation risk within an organization.*

4.9 E6: Covert Channel Capacity (Preliminary, Negative Result)

We use the term *covert channel* only for this experiment and for E3, following Lampson’s definition of an intentional sender modulating a shared resource [Lampson, 1973]; E1, E2, E4, and E5 measure

Gate	Salary	Security	Budget	Mean
None	90%	100%	100%	97%
Hard ownership	0%	0%	0%	0%
Suspicion	30%	40%	30%	33%

Table 7: M3: E3 crafted-memory Mallory placement under gating.

incidental leakage with no sender intent, which we do not call a channel. We attempted to encode an 8-bit payload into crafted memory placement under Config B. Reliable sequential decoding fails: individual payload memories can each be placed reliably in top- k in isolation (consistent with E3), but under sequential multi-bit transmission per-bit error rates rise sharply with payload position — 0% for bits 1–2, 50% for bits 3–4, and 100% for bits 5–8 (full bit-position breakdown in Appendix H)), so structured, error-correcting encoding is required beyond simple positional placement. We report this negative result to calibrate the strength of the covert-channel framing rather than to claim a functioning channel, and note that none of our core claims (E1–E5) depend on E6.

4.10 Mitigation Evaluation

We evaluate three architectural mitigations under Config B (MiniLM + retrieval prefixes). Mitigation 1 (M1) tests metadata filtering; Mitigation 2 (M2) tests ownership-aware embedding proxies; Mitigation 3 (M3) tests post-retrieval ownership gating on E3 active exploitation and E4 downstream contamination with Gemini 2.5 Flash and Claude Sonnet 4.5. We also considered LLM-based memory selection as an alternative to embedding-similarity retrieval but did not evaluate it empirically; we discuss its tradeoffs in Appendix D.

M1: Metadata filtering. We re-run E3 crafted-memory attacks under four store conditions (Table 6). Partitioned retrieval with same-user queries eliminates Mallory top- k placement (0%). Cross-user query wording alone does not bypass partitioning (0%). Failure occurs only when the store scope explicitly includes the attacker (*scoped_cross* with Mallory), restoring 90–100% placement.

M2: Ownership-aware embeddings. We test two proof-of-concept proxies without full user-conditioned encoder training (full per-tier table in Appendix I). *Prefix injection* prepends a user-identity token to every memory and query before embedding, reducing T0 leakage from 70% to 50% while *increasing* same-user utility (0.384 to 0.506). *Namespace offset* instead adds a fixed per-user vector to memory embeddings and subtracts the querying user’s offset at retrieval time; this variant increases leakage and degrades utility across T0–T2, indicating that post-hoc offset schemes disrupt same-user retrieval more than cross-user similarity and that user-conditioned encoder training remains necessary for this approach to work.

Path	Model	Gate	Sal.	Sec.	PIP	Mean	Help.
Static	Flash	None	3.0	1.0	4.0	2.67	4.80
Static	Flash	HO	1.0	1.0	1.0	1.00	4.67
Retrieval	Flash	None	5.0	5.0	5.0	5.00	5.00
Retrieval	Flash	HO	1.0	1.0	1.0	1.00	4.67
Static	Sonnet	None	5.0	4.0	5.0	4.67	4.53
Static	Sonnet	HO	1.0	1.0	1.0	1.00	2.60
Retrieval	Sonnet	None	5.0	5.0	4.0	4.67	2.67
Retrieval	Sonnet	HO	1.0	1.0	1.0	1.00	3.80

Table 8: M3: E4 contamination scores (1–5) with and without hard ownership (HO) gate. Sal./Sec./PIP = per-scenario leaked contamination; Help. = mean helpfulness of leaked responses. Retrieval/None rows reproduce E4 retrieval-path baselines (Table 5); gated rows from M3 runs.

M3: Post-retrieval ownership gating. We apply a *hard ownership gate* (drop hits where owner $\neq$ querying user) and a *suspicion gate* (drop cross-user hits exceeding a similarity threshold) after

pooled retrieval. Hard ownership gating eliminates Mallory placement in E3 (0%; Table 7) and reduces mean E4 contamination to 1.00/5, which is the clean baseline for both generation models and both memory paths (Table 8). The suspicion gate is insufficient for active exploitation, permitting 30–40% attacker placement. Under Flash, helpfulness remains high with gating (4.67/5). Under Sonnet, gating reduces contamination equally but helpfulness drops to 2.60–3.80/5 in the gated condition, reflecting the tradeoff between privacy and context richness that follows from removing cross-user memories, rather than a defect in the gating mechanism itself.

Operational overhead of the recommended mitigation. Because deploying hard ownership gating has a concrete engineering cost, we benchmark its retrieval latency alongside the other mitigations over 1,000 query cycles against a 10,000-memory pgvector HNSW index (full per-mechanism table in Appendix J). Applying deterministic post-retrieval ownership gating (M3) adds roughly 1.4 ms of mean latency per query while eliminating measured response contamination, indicating the mitigation is deployable at negligible cost in a realistic serving path. M1’s contamination score in Table 14 reflects the partitioned-store condition in which metadata filtering succeeds (Table 6); it does not eliminate contamination once an attacker falls within an intentionally widened retrieval scope (§4.10, “Active failure”).

Scaling to higher-dimensional enterprise embedding models. Because Config B uses a relatively small 384-dimensional encoder, we spot-checked two higher-dimensional embedding models on the T0 pair (full table in Appendix K): rates ranged 70–80% and were not statistically distinguishable at $n = 10$, so we do not claim any one embedder is worse. The conservative finding is that leakage does not *diminish* with embedder scale, meaning our MiniLM-based results are not an artifact of an unusually weak encoder.

5 Limitations.

Our results rest on a controlled proof-of-concept design: four hand-authored synthetic user pairs and $n = 10$ queries per condition (three scenarios for downstream contamination), so fine-grained rank orderings between conditions with overlapping 95% Wilson intervals (e.g., T1/T2 vs. T0 in E2, or the Resonance Index ordering in E5) should be read as suggestive rather than established, and our rates are not a population-level prevalence estimate for real enterprise deployments. Memories and queries are fixed, hand-authored fixtures rather than samples from production logs, and we have not verified their representativeness. Downstream contamination and helpfulness in E4/M3 are scored by the same model family used as generator; a small human-agreement pilot ($n = 9$, Section 4.7) found strong agreement on clean controls and helpfulness but weaker agreement on contamination, with the one disagreement suggesting our reported numbers are a conservative lower bound rather than an inflated estimate. We study only embedding-similarity retrieval and evaluate two generation/judge models, and our mitigations are proof-of-concept implementations rather than production deployments. A full discussion of these points, plus additional limitations regarding covert-channel capacity and infrastructure scope, appears in Appendix A.

6 Conclusion

We introduce MemLeak, a study of inter-user information leakage in multi-tenant AI agent memory systems that pool user memories in a shared vector store with soft, metadata-based ownership rather than hard partitioning. Under pooled same-team retrieval, incidental leakage reaches 70–100% depending on embedder; adversarially crafted memories achieve 90–100% top- k placement, exceeding weaker keyword-based baselines, with score lifts of +0.416 to +0.511; and downstream responses exhibit contamination increases of +1.67 to +4.00 points while often remaining highly helpful, a gap we validate against human judgment. The complete E4 2×2 design confirms that both generation model and retrieval path materially affect exfiltration severity. Mitigation evaluation demonstrates that metadata filtering alone is insufficient once retrieval scope widens to include an attacker, prefix injection partially reduces leakage, and hard post-retrieval ownership gating consistently restores contamination to the clean baseline (1.00/5) for both Gemini 2.5 Flash and Claude Sonnet 4.5, at a measured latency overhead of roughly 1.4 ms per query. Trustworthy multi-tenant personalization requires layered defenses at the store, embedding, and post-retrieval layers; system designers must evaluate retrieval architecture and generation model selection jointly.

References

- Anthropic. The claude 3 model family: Opus, sonnet, haiku. URL <https://api.semanticscholar.org/CorpusID:270640496>.
- Anthropic. Claude sonnet 4.5 system card, September 2025. URL <https://www.anthropic.com/claude-sonnet-4-5-system-card>.
- Nicholas Carlini, Florian Tramèr, Eric Wallace, Matthew Jagielski, Ariel Herbert-Voss, Katherine Lee, Adam Roberts, Tom Brown, Dawn Song, Úlfar Erlingsson, Alina Oprea, and Colin Raffel. Extracting training data from large language models. In *30th USENIX Security Symposium (USENIX Security 21)*, pages 2633–2650. USENIX Association, August 2021. ISBN 978-1-939133-24-3. URL <https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting>.
- Harsh Chaudhari, Giorgio Severi, John Abascal, Matthew Jagielski, Christopher A Choquette-Choo, Milad Nasr, Cristina Nita-Rotaru, and Alina Oprea. Phantom: General trigger attacks on retrieval augmented language generation. *arXiv preprint arXiv:2405.20485*, 2024.
- Prateek Chhikara, Dev Khant, Saket Aryan, Taranjeet Singh, and Deshraj Yadav. Mem0: Building production-ready ai agents with scalable long-term memory. *arXiv preprint arXiv:2504.19413*, 2025.
- Gheorghe Comanici, Eric Bieber, Mike Schaekermann, Ice Pasupat, Noveen Sachdeva, Inderjit Dhillon, Marcel Blistein, Ori Ram, Dan Zhang, Evan Rosen, et al. Gemini 2.5: Pushing the frontier with advanced reasoning, multimodality, long context, and next generation agentic capabilities. *arXiv preprint arXiv:2507.06261*, 2025.
- Dorothy E Denning. A lattice model of secure information flow. *Communications of the ACM*, 19(5): 236–243, 1976.
- Oluwaseyi Feyisetan, Borja Balle, Thomas Drake, and Tom Diethe. Privacy-and utility-preserving textual analysis via calibrated multivariate perturbations. In *Proceedings of the 13th international conference on web search and data mining*, pages 178–186, 2020.
- Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world llm-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security, AISec ’23*, page 79–90, New York, NY, USA, 2023. Association for Computing Machinery. ISBN 9798400702600. doi: 10.1145/3605764.3623985. URL <https://doi.org/10.1145/3605764.3623985>.
- Jiahe Guo, Xiangran Guo, Yulin Hu, Zimo Long, Xingyu Sui, Xuda Zhi, Yongbo Huang, Hao He, Weixiang Zhao, Yanyan Zhao, and Bing Qin. When personalization legitimizes risks: Uncovering safety vulnerabilities in personalized dialogue agents. *arXiv preprint arXiv:2601.17887*, 2026.
- Nikhil Kandpal, Eric Wallace, and Colin Raffel. Deduplicating training data mitigates privacy risks in language models. In *International Conference on Machine Learning*, pages 10697–10707. PMLR, 2022.
- Butler W. Lampson. A note on the confinement problem. *Commun. ACM*, 16(10):613–615, October 1973. ISSN 0001-0782. doi: 10.1145/362375.362389. URL <https://doi.org/10.1145/362375.362389>.
- Patrick Lewis, Ethan Perez, Aleksandra Piktus, Fabio Petroni, Vladimir Karpukhin, Naman Goyal, Heinrich Küttler, Mike Lewis, Wen-tau Yih, Tim Rocktäschel, Sebastian Riedel, and Douwe Kiela. Retrieval-augmented generation for knowledge-intensive nlp tasks. In *Advances in Neural Information Processing Systems*, volume 33, pages 9459–9474, 2020.
- Zhiyu Li, Shichao Song, Hanyu Wang, Simin Niu, Ding Chen, Jiawei Yang, Chenyang Xi, Huayi Lai, Jihao Zhao, Yezhaohui Wang, Junpeng Ren, Zehao Lin, Jiahao Huo, Tianyi Chen, Kai Chen, Ke-Rong Li, Zhiqiang Yin, Qingchen Yu, Bo Tang, Hongkang Yang, Zhiyang Xu, and Feiyu Xiong. Memos: An operating system for memory-augmented generation (mag) in large language models. *ArXiv*, abs/2505.22101, 2025. URL <https://api.semanticscholar.org/CorpusID:278960153>.

- John Morris, Volodymyr Kuleshov, Vitaly Shmatikov, and Alexander Rush. Text embeddings reveal (almost) as much as text. In Houda Bouamor, Juan Pino, and Kalika Bali, editors, *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing*, pages 12448–12460, Singapore, December 2023. Association for Computational Linguistics. doi: 10.18653/v1/2023.emnlp-main.765. URL <https://aclanthology.org/2023.emnlp-main.765/>.
- Andrew C Myers and Barbara Liskov. A decentralized model for information flow control. *ACM SIGOPS Operating Systems Review*, 31(5):129–142, 1997.
- Charles Packer, Vivian Fang, Shishir G. Patil, Kevin Lin, Sarah Wooders, and Joseph E. Gonzalez. Memgpt: Towards llms as operating systems. *CoRR*, abs/2310.08560, 2023. URL <https://doi.org/10.48550/arXiv.2310.08560>.
- Joon Sung Park, Joseph O’Brien, Carrie Jun Cai, Meredith Ringel Morris, Percy Liang, and Michael S. Bernstein. Generative agents: Interactive simulacra of human behavior. In *Proceedings of the 36th Annual ACM Symposium on User Interface Software and Technology*, UIST ’23, New York, NY, USA, 2023. Association for Computing Machinery. ISBN 9798400701320. doi: 10.1145/3586183.3606763. URL <https://doi.org/10.1145/3586183.3606763>.
- Fabio Perez and Ian Ribeiro. Ignore previous prompt: Attack techniques for language models. *arXiv preprint arXiv:2211.09527*, 2022.
- Sidharth Pulipaka, Oliver Chen, Manas Sharma, Taaha S Bajwa, Vyas Raina, and Ivaxi Sheth. Persist-bench: When should long-term memories be forgotten by llms? *arXiv preprint arXiv:2602.01146*, 2026.
- Avital Shafran, Roei Schuster, and Vitaly Shmatikov. Machine against the {RAG}: Jamming {Retrieval-Augmented} generation with blocker documents. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 3787–3806, 2025.
- Noah Shinn, Federico Cassano, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. Reflexion: Language agents with verbal reinforcement learning. *Advances in neural information processing systems*, 36:8634–8652, 2023.
- Haoran Tan, Zeyu Zhang, Chen Ma, Xu Chen, Quanyu Dai, and Zhenhua Dong. Membench: Towards more comprehensive evaluation on the memory of llm-based agents. In *Findings of the Association for Computational Linguistics: ACL 2025*, pages 19336–19352, 2025.
- Lei Wang, Chengbang Ma, Xueyang Feng, Zeyu Zhang, Hao ran Yang, Jingsen Zhang, Zhi-Yang Chen, Jiakai Tang, Xu Chen, Yankai Lin, Wayne Xin Zhao, Zhewei Wei, and Ji rong Wen. A survey on large language model based autonomous agents. *Frontiers of Computer Science*, 18, 2023. URL <https://api.semanticscholar.org/CorpusID:261064713>.
- Liang Wang, Nan Yang, Xiaolong Huang, Binxing Jiao, Linjun Yang, Daxin Jiang, Rangan Majumder, and Furu Wei. Text embeddings by weakly-supervised contrastive pre-training. *ArXiv*, abs/2212.03533, 2022. URL <https://api.semanticscholar.org/CorpusID:254366618>.
- Di Wu, Hongwei Wang, Wenhao Yu, Yuwei Zhang, Kai-Wei Chang, and Dong Yu. Longmemeval: Benchmarking chat assistants on long-term interactive memory. In *Proceedings of the International Conference on Learning Representations*, 2025.
- Wujiang Xu, Zujie Liang, Kai Mei, Hang Gao, Juntao Tan, and Yongfeng Zhang. A-mem: Agentic memory for LLM agents. In *The Thirty-ninth Annual Conference on Neural Information Processing Systems*, 2025. URL <https://openreview.net/forum?id=Fim0M8gcct>.
- Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik R Narasimhan, and Yuan Cao. React: Synergizing reasoning and acting in language models. In *The Eleventh International Conference on Learning Representations*, 2023. URL https://openreview.net/forum?id=WE_vluYUL-X.
- Lianmin Zheng, Wei-Lin Chiang, Ying Sheng, Siyuan Zhuang, Zhanghao Wu, Yonghao Zhuang, Zi Lin, Zhuohan Li, Dacheng Li, Eric Xing, Hao Zhang, Joseph E. Gonzalez, and Ion Stoica. Judging LLM-as-a-judge with MT-bench and chatbot arena. In *Thirty-seventh Conference on Neural Information Processing Systems Datasets and Benchmarks Track*, 2023. URL <https://openreview.net/forum?id=uccHPGDlao>.

Wei Zou, Runpeng Geng, Binghui Wang, and Jinyuan Jia. Poisonedrag: knowledge corruption attacks to retrieval-augmented generation of large language models. In *Proceedings of the 34th USENIX Conference on Security Symposium, SEC '25, USA, 2025*. USENIX Association. ISBN 978-1-939133-52-6.

A Extended Limitations

Section 6 gives a condensed summary of our limitations; the full discussion is given here.

Sample size and statistical precision. All leakage, placement, and contamination rates are computed over small samples: $n = 10$ queries per user pair per tier (E1, E2, E3, E3b), and 3 scenarios for downstream contamination (E4, M3). We report 95% Wilson-score confidence intervals throughout; fine-grained rank orderings among conditions with overlapping intervals (e.g., the specific ordering of T0 vs. T1/T2 in E2, or the specific ranking of T0–T2 by Resonance Index in E5) should be read as suggestive rather than established, and we reserve strong claims for contrasts with non-overlapping intervals (pooled vs. partitioned retrieval; T3 vs. T0–T2). Our four hand-built user pairs and three contamination scenarios constitute a controlled proof-of-concept design intended to demonstrate the existence and mechanism of cross-user leakage, not a population-level prevalence estimate for real enterprise deployments.

Synthetic data. Memories and queries are hand-authored fixtures representing plausible categories of sensitive professional information (salary, security, HR, budget) rather than samples from real user data or production logs (full fixtures released in Appendix E). We have not verified that these fixtures are representative of real enterprise memory distributions, vocabulary overlap patterns, or query phrasing, and treat this as an open limitation rather than a validated assumption.

Evaluation bias in E4 and M3. Downstream contamination and helpfulness are scored by the same model family used as generator (self-judging), which can introduce bias. We partially address this with a human-agreement pilot (E0, Section 4.7, $n = 9$ responses), which found reasonable-to-strong agreement on clean controls and helpfulness (MAE 0.53) but weaker agreement on contamination (MAE 0.79), with the single largest disagreement being a case where the judge under-scored genuine disclosure. This suggests our contamination numbers are a conservative lower bound, but $n = 9$ is too small to fully validate the judge, and cross-model judge-generator pairings (e.g., judging Gemini outputs with a Claude judge) remain future work.

Model and infrastructure scope. Our downstream generation/judge models (Gemini 2.5 Flash, Claude Sonnet 4.5) may not represent the full range of models used in production enterprise agents, and results could differ with larger or smaller models. Our embedding-scaling spot-check (Table 15) covers three additional encoders on a single tier and is not a comprehensive study of embedding-model effects. Mitigation experiments use proof-of-concept implementations (prefix tokens, post-hoc namespace offsets, hard/suspicion gates) rather than production deployments; the retrieval path for most experiments uses in-memory cosine search, and only the latency benchmark (Table 14) uses production pgvector/HNSW infrastructure, at a single over-fetch factor ($K = 15$). Namespace-offset mitigation (M2) is not viable as tested and would require full user-conditioned encoder training to evaluate properly, which is beyond the scope of this work.

Covert-channel capacity. E6’s negative bandwidth result (rising to 100% bit-error rate at bits 5–8) indicates that Shannon-capacity-style measurement of the active-exploitation channel requires structured, error-correcting encoding schemes beyond simple positional placement, which we leave to future work; we do not claim to have demonstrated a channel with controllable throughput, only that individual crafted-memory placement is reliable (E3).

Alternative retrieval mechanisms. We study only embedding-similarity retrieval, the dominant recall mechanism in the general-purpose memory infrastructure our threat model targets (Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], MemOS [Li et al., 2025]); we do not empirically evaluate LLM-based memory selection or other non-embedding retrieval mechanisms, which may have different (not necessarily better) leakage properties and their own attack surface (Appendix D). Future work should evaluate larger and more diverse enterprise embedding models (e.g., gemini-embedding) at scale, learned multi-user MemGate-style extensions, independent human adjudication at larger sample sizes, cross-model judge-generator pairings, LLM-based memory selection as an alternative retrieval mechanism, and a fully worked structured encoding scheme for covert-channel capacity.

B Evaluation Metrics

Table 9 defines every metric used in Section 4.

Metric	Definition
LR	Fraction of queries with ≥ 1 cross-user memory in top- k
MCR	Mean rank of highest-placed cross-user memory
Score Gap	Mean(max cross-user score – min same-user score)
Centroid Sim.	Cosine sim. between user memory centroids
Top- k Placement	Fraction with attacker memory in top- k
Score Lift	Mean(crafted score – organic score)
Contam. Score	Judge-rated cross-user disclosure (1–5)
Helpfulness	Judge-rated utility for querying user (1–5)
XLR	Cross-user leakage rate
Resonance Index [†]	$0.35 \cdot \text{centroid} + 0.25 \cdot \text{Jaccard} + 0.40 \cdot \text{XLR}$
ICG	Helpful(leaked) – Helpful(clean)
BER	Bit error rate for covert payload

Table 9: Evaluation metrics across all experiments. [†]The Resonance Index weights (0.35/0.25/0.40) are a heuristic, illustrative composite chosen for interpretability, not fit or validated against any ground-truth harm signal; it is exploratory (Section 4.8), and none of our core claims depend on it: they rest directly on the underlying leakage-rate, top- k placement-rate, and contamination measurements.

C Broader impacts.

This work has a dual-use dimension: 4.5 document a technique (crafted bridging) by which an adversary with only topical/role knowledge of a victim – not query-level or embedding-model access – can reliably steer cross-user retrieval, closing most of the gap to an oracle upper bound (E3b). We disclose this mechanism because (i) it is a natural consequence of deploying pooled or under-scoped memory stores already in production use (Mem0, A-Mem, MemOS), so the risk exists whether or not it is named here; (ii) we pair it with a mitigation (M3, hard post-retrieval ownership gating) that eliminates the attack in our evaluation at negligible latency cost (§4.10); and (iii) our attacker methodology requires no capability beyond what a malicious or compromised in-scope team member already has in the deployment patterns we study (§3). In our judgment, the value of surfacing an under-examined multi-tenant failure mode – together with a low-cost fix – outweighs the incremental risk of documenting a technique that follows directly from the already-public architecture of pooled vector-store retrieval.

D Extended Discussion: Deployment Patterns, Statistical Notes, and Alternative Retrieval

Full deployment-pattern taxonomy (Section 3.5). MemLeak’s threat model is not the trivial fully-absent-ACL case but four deployment patterns in which cross-user memories remain reachable by design or by common misconfiguration, following patterns documented in general-purpose agent-memory libraries such as Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], and MemOS [Li et al., 2025]: (1) *pooled indices with under-scoped metadata filters*, e.g., a filter applied at the level of “all of Engineering” rather than per user; (2) *legitimate collaboration or team-scoped retrieval*, where the store intentionally widens to include a project team, and a compromised or malicious

member of that scope becomes an in-scope attacker; (3) *role- or project-shared memory namespaces*, where users legitimately sharing a namespace can still have a colleague’s private memory surface for an unrelated query; and (4) *scoped enterprise workflows* (HR, finance, security) where cross-user content belongs in the retrieval pool by policy, but where memory admissibility should still depend on more than raw similarity.

Extended E2/E5 statistical notes. T1 and T2 (90% LR under Config B) show a nominally higher leakage rate than T0 (70%), despite T0 having the highest centroid similarity (0.570) of the three. At $n = 10$, however, the Wilson intervals for 70% ([40%, 89%]) and 90% ([60%, 98%]) overlap substantially, so this specific ordering (T1/T2 above T0) is not statistically distinguishable from chance at our sample size, and we do not offer a mechanistic account of *why* T1/T2 exceed T0. Likewise in E5, T2 (cross-department) shows the highest Resonance Index (0.549) among the four tiers; as with the E2 ordering, we treat the specific rank ordering of the Resonance Index across T0–T2 as suggestive rather than statistically established at $n = 10$ per tier. In both cases the coarser, robust signal is the same: the cross-company control (T3) sits in a clearly separated, favorable region (low leakage, high utility), while T0–T2 are not reliably distinguishable from one another at our sample size.

Budget Authority case study (Section 4, E3). The Budget Authority scenario merits specific attention: Config A organic placement reaches 70%, meaning the attacker’s unmodified memories already appear in top- k for 7 of 10 target queries without any crafting. This arises because budget authority vocabulary (approval thresholds, spend categories, procurement language) is broadly shared across professional roles, making the attacker’s organic memories semantically proximate to the target’s queries by coincidence. Two implications follow. First, the absolute score lift for this scenario (+0.484, Config A) understates attacker advantage relative to near-zero-baseline scenarios, since the marginal gain from crafting is compressed when the floor is already high. Second, high organic placement in financially-adjacent roles represents an incidental leakage risk independent of adversarial intent, consistent with the E1–E2 finding that pooled retrieval leaks without exploitation.

Alternative retrieval mechanisms (Section 4.10). We focus throughout on embedding-similarity retrieval because it is the recall mechanism implemented by the general-purpose agent-memory libraries most exposed to the deployment patterns we study (Mem0 [Chhikara et al., 2025], A-Mem [Xu et al., 2025], MemOS [Li et al., 2025]). An alternative worth discussing is LLM-based memory selection, where a small language model is prompted to choose relevant memories from the full store rather than ranking by cosine similarity. Such a selector could reduce reliance on raw embedding proximity and might be conditioned on user identity more easily than a similarity threshold, but it introduces two new costs and risks rather than eliminating the problem: latency and token cost scale with memory-store size since the selector must see (or be routed to a subset of) candidate memories, and the selection step is itself a new attack surface for indirect prompt injection from stored memory content, distinct from the pure similarity-based leakage we study here. We do not evaluate LLM-based selection empirically and flag it as future work.

E Dataset Construction

Memories (10 per user) and queries (10 per user) are hand-authored, fixed natural-language fixtures spanning four domain categories, held constant across all four organizational-distance tiers (T0–T3) to isolate the effect of organizational distance from content variation:

- **Salary negotiation:** source-user memories cover compensation benchmarks and equity vesting detail; target-user queries are managerial compensation questions.
- **Security policy:** source-user memories cover infrastructure vulnerability detail; target-user queries are security-audit questions.
- **HR / PIP decisions:** source-user memories cover performance improvement plan detail; target-user queries are restructuring questions.
- **Budget authority:** source-user memories cover spending-approval detail; target-user queries are procurement questions.

Full fixture text (all memories and queries for all eight synthetic users across T0–T3) and the LLM-judge meta-prompts used in E4/M3 (persona, task, rubric, context, and JSON output schema; contamination anchors range from “1 = no cross-user private information revealed” to “5 = explicit detailed disclosure of confidential cross-user information,” mapped from a normalized $[0, 1]$ judge score s to the paper’s 1–5 scale via $\text{paper} = 4s + 1$) are provided in the supplementary material.

F E3b: Full Attacker-Knowledge Ablation

Section 4.5 reports the attacker-knowledge ablation for the Salary Negotiation scenario only. Table 10 gives the full breakdown for that scenario, including Config A and 95% Wilson confidence intervals. The full scenario $\times$ baseline $\times$ configuration grid across all three scenarios (Salary, Security, Budget) follows the same qualitative pattern: organic placement is highest for Budget Authority (consistent with Appendix D’s discussion of broadly shared procurement vocabulary), domain-keyword and per-query-keyword baselines each close part of the gap to crafted bridging, and crafted bridging closes most of the remaining gap to the verbatim-copy oracle across all three scenarios. The complete per-scenario table is provided in the supplementary material.

Condition	Cfg. A	Cfg. B	
	Pl.%	Pl.%	Lift
Organic (none)	30% [11,60]	10% [2,40]	ref
Keyword bag	70% [40,89]	40% [17,69]	+0.182
Per-query kw.	90% [60,98]	80% [49,94]	+0.345
Crafted (ours)	100% [72,100]	90% [60,98]	+0.416
Verbatim (oracle)	100% [72,100]	100% [72,100]	+0.488

Table 10: E3b attacker-knowledge ablation (Salary Negotiation). Pl.% = top- k placement rate, with 95% Wilson CI stacked below; Lift = mean score increase over the organic baseline under Config B.

G E0: Full Judge/Human Agreement Protocol

Section 4.7 summarizes this pilot; full protocol and per-scenario agreement statistics are given here. To assess whether our LLM-as-judge contamination and helpfulness scores (E4, M3) are trustworthy, two authors independently labeled nine synthetic E4 responses (Gemini 2.5 Flash generator) spanning three scenarios (Salary, Security, PIP) under three conditions each (clean contamination, leaked contamination, leaked helpfulness), applying the same rubric given to the LLM judge. Agreement is

Metric	κ	MAE	± 1	r
Clean control	1.00	0.00	100%	1.00
Salary contam.	0.62	0.50	100%	0.81
Security contam.	0.48	1.33	67%	0.42
PIP contam.	0.55	0.33	100%	0.78
Overall	0.53	0.79	78%	0.66

Table 11: E0 human–LLM judge agreement pilot ($n = 9$ responses). κ = human–human agreement; MAE = mean absolute error (human label vs. judge score); ± 1 = fraction of judge scores within 1 point of the human label; r = Pearson correlation.

high on clean controls and on helpfulness (mean absolute error 0.53 across conditions) but weaker on contamination overall (MAE 0.79), driven almost entirely by a single miss on the Security scenario, where the judge scored an unpatched-CVE detail as generic security advice (1.0) while both human annotators scored it as explicit disclosure (5.0). This single miss is directionally conservative (it causes the judge to *under*-score disclosure, not over-score it), so we treat our reported E4/M3

contamination numbers as a lower bound on true leakage severity rather than an inflated estimate. We view judge alignment as an area needing further prompt iteration (e.g., supplying the judge with the leaked memory text itself rather than only its category, and adding few-shot examples distinguishing generic advice from scenario-specific leaked detail) and report this pilot as a limitation rather than a validation.

H E6: Covert Channel Capacity, Full Bit-Position Breakdown

Section 4.9 summarizes this negative result; the full bit-position breakdown is given here. We encoded an 8-bit payload into crafted memory placement under Config B. Early bits align well

Bits	Placement	Error	Cause
1-2	top-2	0%	semantic align.
3-4	top-5+	50%	user competition
5-8	outside top- k	100%	similarity cutoff

Table 12: E6 sequential bit-position decode failure under Config B. Cause = dominant reason placement failed at that bit position.

Variant	T0 LR	T0 Util.	T1 LR	T2 LR	T3 LR
Baseline	70%	0.384	90%	90%	10%
Prefix injection	50%	0.506	90%	80%	10%
Namespace offset	100%	0.145	100%	100%	60%

Table 13: M2 (§I): pooled leakage rate (LR) and same-user utility by tier.

with the query semantics, but later bits are progressively displaced by competition from legitimate same-user memories and eventually rejected outright by the similarity cutoff. This shows crafted placement of a *single* item is a real and repeatable effect (E3), but we have not demonstrated a channel with controllable throughput: sequential multi-bit transmission requires structured, error-correcting encoding schemes beyond simple positional placement, which we leave to future work.

I M2: Full Ownership-Aware Embedding Results

Section 4.10 summarizes these results; the full per-tier table (Table 13) is given above, alongside the E6 bit-position table for space.

J Mitigation Latency Benchmark, Full Table

Section 4.10 summarizes this benchmark. We measured retrieval latency and throughput over 1,000 query cycles against a 10,000-memory pgvector HNSW index, using an over-fetch factor of $K_{\text{retrieved}} = 15$ candidates before filtering down to top- $k = 3$.

Mechanism	Latency	Δ	Contam.
Unfiltered	12.4 ms	n/a	5.00/5
M1: filter	14.2 ms	+1.8 ms	1.00/5
M2: prefix	12.5 ms	+0.1 ms	2.60/5
M3: hard gate	13.8 ms	+1.4 ms	1.00/5

Table 14: Latency/contamination tradeoff ($n=1,000$ cycles, 10k-memory pgvector HNSW, over-fetch $K=15$). Contam. = E4 score. **Note:** the M1 row reflects the partitioned-store condition (Table 6, “Passive safe” row), where metadata filtering succeeds. Under the “Active failure” condition (attacker in-scope), M1 does not eliminate contamination — see §4.10 and Table 6. M1’s latency figure is condition-independent.

Model	Dim.	T0 LR [95% CI]	Top-1 gap
all-MiniLM-L6-v2	384	70% [40,89]	+0.095
bge-large-en-v1.5	1024	80% [49,94]	+0.112
text-embed-3-small	1536	70% [40,89]	+0.104

Table 15: Incidental leakage rate (T0, pooled) across embedding models of increasing dimensionality (§K).

K Embedding-Model Scaling Spot-Check, Full Table

Section 4.10 summarizes this spot-check. Because Config B uses a relatively small 384-dimensional encoder (all-MiniLM-L6-v2), we checked whether incidental leakage persists under higher-dimensional embedding models more representative of enterprise deployments, on the T0 same-team pair (Table 15, shown above alongside the latency benchmark for space). The three rates are not statistically distinguishable from one another at $n = 10$, so we do not claim any one embedder is worse; the finding we report is the more conservative one that leakage does not *diminish* with embedder scale or dimensionality across the models tested, meaning our MiniLM-based results are not an artifact of using an unusually weak or low-capacity encoder.